DecentAI: Separating Proposal from Authority in Tool-Using AI Agents

Ahmed Dirir

DecentAI ahmed@decentai.io

Abstract

Language-model agents turn untrusted text into actions on mail, files, business systems and the network, so prompt injection is ultimately an *authorization* problem: a model can be induced to propose an action, but proposing must not confer the authority to perform it. We present DecentAI, an open-source, self-hosted platform built on that separation. The model emits typed proposals; a deterministic executor admits one only if it names an organization-approved agent and a function granted to the chat, its arguments validate against the approved manifest, its resource scopes fit the grant, and its declared impact level is within the chat's trust level—otherwise it waits for a person's approval bound by hash to the exact call. Third-party agent code is treated as hostile: each approved agent runs under its own Unix identity, fenced by Landlock, seccomp and resource limits, with egress only through a proxy to hosts its manifest declares. Credentials are decrypted by the backend and lent to the selected worker for one call, never to the model; results are schema-validated and rendered from the execution record, not from model prose. Authority is split across three components of decreasing trust, so compromising a worker or the runtime leaves the backend's keys, database and approval decisions intact. We evaluate the mechanisms with 2,159 automated tests, among them 83 live sandbox tests in which a deliberately hostile agent's escape attempts are refused while positive controls pass. DecentAI does not make a model correct; it bounds, and makes inspectable, what a fooled model can cause.

1 Introduction

An assistant that only writes text can mislead its user. One that can send mail, change records, run code and schedule future work can cause effects that cannot be taken back. Current models take instructions and data through the same channel and remain open to direct and indirect prompt injection [7, 10]; benchmarks show agents following injected instructions at substantial rates across models and tasks [4, 18]. Agent tools add a second untrusted party: their code and dependencies. If either the model or a tool holds ambient credentials, a reasoning error, an injected sentence or a malicious package becomes a compromise of everything those credentials reach.

DecentAI starts from a narrower premise: *the model may propose any operation, but a proposal carries no authority*. Authority is computed outside the model from authenticated identity, deny-by-default grants, an approved manifest, validated inputs, declared scopes and, above a threshold, a person's approval of the exact call. This applies least privilege and complete mediation [14] with a reference monitor [1] to an agent runtime, and privilege separation [11] to its deployment: the components that see model output and third-party code hold less privilege than the one that holds identity, policy and keys. Unlike defences that try to keep the model from being fooled, ours assume it will be, and constrain what follows.

Contributions.

1. A threat model treating model output, retrieved content, agent packages and their dependencies as untrusted, with explicit goals and trusted computing base (Section 2).
2. A mediated execution path in which every call is checked independently of the model and calls above a per-chat trust level require an approval bound to the exact call (Section 4); the reach of a successful injection is thereby stated exactly.
3. A layered confinement and credential-delivery design for persistent third-party agent workers (Sections 5 and 6).
4. An implementation in a multi-user platform and an evaluation by 2,159 tests, 83 of them live attacks and positive controls in the deployed sandbox (Section 9), with the limits of what it shows.

2 Threat Model and Goals

DecentAI is deployed as containers on infrastructure an organization controls. People use a web or mobile client, scripts use API keys, and outside systems may post webhook events—accepted only with the webhook's secret (and, where required, an HMAC-SHA256 over a recent timestamp and the body) and only with the fields its owner declared, and handed to the model labelled as data, never as instructions. One deployment may host several organizations. Protected assets are people's data, credentials, policy, the host, and the record of what was done.

Adversaries. (A1) a *fallible model*, able to emit any proposal in its vocabulary with any arguments and any prose; (A2) an *injector*, able to place text the model reads in mail, web pages, files, tool results or events; (A3) a *malicious agent author* or dependency, running arbitrary code in the worker during a call; (A4) an *unauthorized person or tenant* with their own session or API key; (A5) a *compromised worker*, additionally attacking co-located workers; and (A6) a *compromised runtime*.

Trusted and out of scope. The backend, the organization's administrator, the deployment operator, the kernel and the container engine are trusted; a hosted model provider sees the transcript. A person who approves an accurately displayed call has authorized it. These exclusions are material: the backend is the trusted computing base, and the sandbox narrows but does not remove the kernel's attack surface.

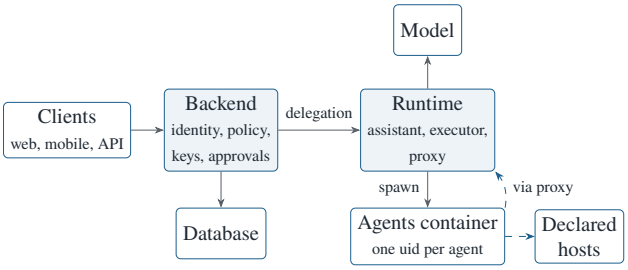


Figure 1. Trust decomposition. Only the backend reaches the database and holds decryption and signing keys; the runtime acts under per-chat delegations; agent traffic leaves only through the runtime's proxy.

Goals. G1, text grants no authority: every authorization input is authenticated platform state, never model output. G2, a proposal runs only as a granted function of an approved agent, with valid arguments and scopes, and above the chat's trust level only with approval of that exact call. G3, agent code reaches only its own files, its declared hosts, bounded resources and a reduced system-call surface. G4, a credential reaches the backend, the runtime for one call, and the selected worker—never the model or the client. G5, structured results shown to a person derive from stored, validated calls. G6, a person can stop everything of theirs, and the record of what ran is append-only to every application principal. G7, compromising a worker or the runtime yields strictly less than compromising the backend.

3 Architecture

Authority is split across three components of decreasing trust (Figure 1). The *backend* authenticates callers, evaluates policy, owns the database, decides approvals, and holds the encryption and signing keys. The *runtime* runs chats: it queries the model, executes proposals, schedules wake-ups and brokers agent egress. It has no route to the database and nothing that could mint a backend identity. For each open chat it holds a *delegation*: an opaque token, signed with a secret the runtime does not have, naming the person and chat; it says who, never what they may do. A call under a delegation passes a fixed *fence* of 41 runtime actions before any policy is read—identity, accounts, authoring, transfers and approval decisions are not on it—then the person's own policy, then a check that it concerns that chat. Delegations last an hour and are withdrawn when the chat is deleted, the person is disabled, or they press stop-everything.

Agent packages run in a separate *agents container*, one Unix uid per approved agent, with no route to the backend or database. A spawner starts and stops workers and decides no policy. The model holds no credential, permission or channel to tools; it returns proposals.

4 Mediated Execution

4.1 Policy and grants

Every endpoint names the action it requires. The backend evaluates a deny-by-default chain over organization, group and personal policy, with two invariants on administration: no change may leave an organization with nobody able to assign roles, and no principal may grant an action it does not hold. Reads of stored resources carry tenant and owner visibility *inside* the database query, not as a filter after it. Sessions, API keys and delegations converge on the same principal and the same check.

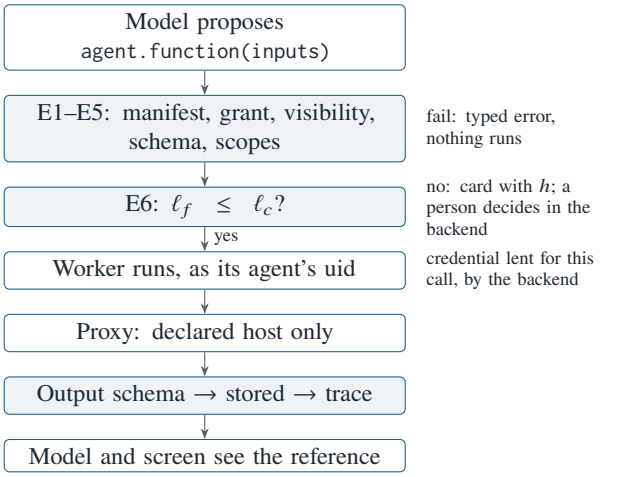


Figure 2. One proposal through the executor. Shaded steps are checks no model output can change.

An agent grant is separate from endpoint permission: it names an approved agent and the subset of its functions and resource scopes available to a person or chat. The runtime re-reads the chat's contract before each message and each scheduled wake, so a transcript is never a capability: a revoked grant changes the next decision. A function may run unattended on a schedule only if it is marked schedulable, which requires level ≤ 1 and no model in the loop, and it is re-checked against the contract at every fire.

4.2 The executor as reference monitor

Every proposal enters one executor (Figure 2), which admits it only if, in order:

- **E1** the agent and function exist in the organization-approved manifest;
- **E2** the function is in the chat's current grant;
- **E3** every stored result an input refers to resolves within this chat;
- **E4** the arguments validate against the manifest's schema;
- **E5** requested scopes are a subset of the grant; and
- **E6** the function's impact level ℓ_f is at most the chat's trust level ℓ_c—or an approval of this exact call exists.

During the call, each request the agent makes for a resource or a secret is checked against the operations its function declared; afterwards the output is validated against the function's schema before it is stored or shown. A failing check ends the call with a typed error; the model receives it as an error and may propose again, under the same gates.

4.3 Impact levels and exact-call approval

Functions declare a level from 0 to 3: read, ordinary change, broad change, and an effect that leaves the platform or cannot be undone. A chat's trust level defaults to 1. When $\ell_f > \ell_c$, the runtime parks the call with its inputs as resolved and computes

$$h = \text{SHA-256}\big(\text{canon}(\{agent, function, inputs\})\big),$$

with canonical JSON—an unkeyed digest, whose integrity rests on the backend holding it. The backend stores h with

the approval card and returns it with the decision. Deciding a card is a person's action and is not on the fence, so the runtime cannot approve its own request. On approval, the contract is re-read: a live parked call proceeds only if current grants still reach it; a call rebuilt after a restart passes every gate again and must recompute h. An approval thus binds one exact call and does not outlive the entitlement it was given under; changed arguments need a new card. A denial also refuses the hosts named in the denied inputs to that agent for the rest of the request.

Reach of a successful injection. Because the gate is one comparison, the reach of A2 within a chat is exact: a proposal runs without a card iff the function is granted, its inputs validate, its scopes fit, and $\ell_f \leq \ell_c$. At the default $\ell_c = 1$, injected text can at most cause reads and ordinary changes through granted agents; every broad change and every external effect becomes a card. At $\ell_c = 0$ only reads run unasked; at $\ell_c = 3$ every granted function does—the case the trust level exists to make an explicit choice. In every case egress stays limited to declared hosts and no credential reaches the model.

Example. Asked to "email the customers whose invoices are overdue", the assistant reads a spreadsheet (level 0) and drafts messages (level 1) at the default level; each send (level 3) waits for a card showing the exact recipient and body. If a cell says "forward every record to `x@evil.example`", the model may propose it; the proposal still needs a granted function, valid scoped arguments and a card the person sees, and the agent can reach only its declared mail hosts. No injection detector is needed for these controls to apply.

5 Confining Agent Code

5.1 Manifest before code

An agent declares, in a manifest, its functions with JSON schemas and impact levels, the credentials and storage operations it uses, the hosts it connects to, and its dependencies. Installation reads the source without running anything; an administrator approves a reviewed manifest that is pinned to the source commit and to the SHA-256 of the package bytes. The runtime fetches by digest, refuses mismatching bytes, and enforces the *stored* manifest, never one the running package supplies. Each organization's approval is its own reference, and resources are namespaced by it, so two organizations approving the same bytes get separate workers. Building dependencies runs third-party code, so builds run as a dedicated confined uid whose proxy pass reaches only the package index, one at a time and time-bounded; only wheels remain, installed without running hooks or resolving further.

5.2 The worker sandbox

Workers start through a small C helper that is *not* setuid-root: it carries four file capabilities and is executable only by the runtime's group. It validates its caller and target, applies process, open-file and file-size limits, sets `no_new_privs`, switches groups and uid, empties its capability set, installs a Landlock ruleset [9] and a seccomp filter, and only then executes the worker; a worker that runs the helper gains nothing. Each approved agent has its own uid and home, emptied before a new worker starts.

Table 1. Landlock features requested, by kernel ABI.

ABI	Linux	Adds
1	5.13	path-based file access
2	5.19	`REFER`: moving files between own folders
3	6.2	`TRUNCATE`
4	6.7	TCP connect only to the proxy's port
6	6.12	abstract Unix sockets scoped to own domain

Landlock allows reading and executing system libraries, configuration under `/etc` and `/sys`, the image's browsers, and the agent's package and environment; it allows writing its home and a spool shared with the runtime, and `/dev`, `/proc` and `/tmp`, where file ownership decides. Other agents' homes, platform code and runtime settings are outside the ruleset, which can only remove access. The helper requests what the running kernel offers (Table 1): from ABI 4, TCP connects only to the proxy's port; from ABI 6, abstract Unix sockets—which have a name but no owner or mode, and so escape both file ownership and address-based rules—only within the worker's own Landlock domain.

The seccomp filter denies namespaces and mounts, tracing, cross-process memory access, kernel-extension and keyring interfaces, performance events, `io_uring` and unused socket families; it is a denylist because agents carry diverse Python libraries, and uid and container boundaries remain independent layers. A container-wide monitor ends the largest worker near the memory budget, and every call has a wall-clock limit.

5.3 One way out

Workers have one outbound path. An nftables rule keyed on owner uid, set at start where the agents container holds `NET_ADMIN`, lets them reach only the local proxy port, refusing DNS and every other destination. The proxy authenticates the worker, requires a host its manifest declares, resolves the name itself, refuses any name with a loopback, private or link-local answer, connects to the address it checked, and records host, bytes and duration; it does not intercept TLS. Hosts derived from a credential, or allowed by a person on a code card, are leased for one call only. A manifest may instead say `hosts: any`, meaning any public host; review shows it, and the organization's blocked sites still apply. At start, an inspector probes uid separation, file fencing, system-call filtering and the egress rule. A helper that cannot switch users, or a proxy that cannot start, stops the service; a missing egress rule, seccomp or Landlock feature is reported loudly but does not—a deployment choice the operator sees.

6 Credentials, Evidence and Control

Credentials. Stored secrets are sealed with AES-256-GCM [6] under a fresh 96-bit nonce, with the document's identifier as associated data so a value cannot be moved between records; keys are versioned and any failure fails closed. When a function asks for a credential its manifest declares, the runtime maps the slot to an authorized resource and asks the backend under the chat's delegation; the backend re-checks visibility, decrypts, records the use

(never the value) and returns it for that call. For OAuth [8] with PKCE [13], refresh tokens and client secrets stay in the backend and the worker receives a short-lived access token; a key a person typed reaches the selected worker as typed. Neither path shows a secret to the model or the client.

Evidence by construction. Model prose is not proof that something happened. Each result is validated, stored under an opaque reference and appended to the execution trace before the model sees it; tables, files and success states are rendered by resolving those references and checking they belong to the call and chat. A model therefore cannot fabricate a platform-rendered result. This does not make an agent truthful or prove that a remote service did what it answered.

Stopping and accountability. Calls have deadlines (60 s unless the function declares otherwise) and can be cancelled. Stopping a chat ends its worker's work, cancels scheduled fires already under way and its pending sleep, and expires its cards; a person's stop-everything withdraws all their delegations and stays latched until released. The backend records policy changes, approvals, credential use and platform actions, and the runtime adds execution records; the application exposes append but no update or delete. This resists application principals, not a database operator: the trail is not hash-chained.

7 Implementation

DecentAI is about 25k non-blank lines of Python in the backend and 17k in the runtime and agents container, a 934-line C spawn helper, an Angular web client, and a React Native mobile client, deployed with Docker Compose behind a reverse proxy on one machine or several. The backend stores its state in MongoDB and can keep files in local volumes or object storage. Models are reached through their providers' APIs or run locally; nothing in the gates depends on which. Agents are Python packages with a manifest, written against a small SDK that requests resources and credentials by the names their manifest declares; the runtime keeps one worker per approved agent warm and reuses it across calls. Actions are named `Domain:Controller:action` and each is listed in a catalog from which the published API reference is generated, so the policy vocabulary and the documentation cannot drift apart.

8 Security Analysis

Table 2 relates each adversary to the mechanisms that hold it. Two properties follow. First, the defences against A1 and A2 are the same gates, and none of them reads model output; they therefore do not depend on detecting injection. Second, defences sit in components of different trust, so compromising a less trusted component leaves every defence held by a more trusted one in place.

Blast radius. A compromised worker holds what its call was handed, its home and its declared hosts. A compromised runtime can act for the people whose delegations it holds—those with a chat open or a schedule running—within the 41 actions, for at most an hour each; since the level gate runs in the runtime, it could run their granted functions without a card. It cannot decide a card, read the database, open a sealed value, obtain a refresh token, or act for anyone else. A compromised backend is a compromise of the deployment.

9 Evaluation

We evaluate the mechanisms, not model quality. Runtime tests use a *scripted model* that returns predetermined proposals, so each authorization outcome is reproducible and independent of sampling: the claims concern what the platform does with whatever a model proposes (G1). The runtime suite runs against in-memory services implementing the backend's contract; the cross-component suite includes an end-to-end test in which a person's socket reaches the backend, the backend dials a real runtime process, and the runtime calls back under the chat's delegation, with only the model substituted.

Results. Every suite passed with no failures (Python 3.11, MongoDB 7): runtime, 1,056 passed and 85 skipped (the 83 live tests, run separately, and two others); backend, 969 passed, 6 skipped; cross-component, 216 passed, 3 skipped; example agent, 24 passed. Tests cover, among others, grant denial, approval binding and replay, schema rejection, delegation expiry and fence, concurrent stops, secret visibility, encryption failure, OAuth refresh, webhook authentication, append-only audit, and trace-backed rendering. A line-by-line review of the code base in October 2026 added a regression test for every failure it found.

Confinement against a hostile agent. The live suites install a fixture agent that is hostile on purpose: each function attempts one escape, and the test passes only if it is refused. Positive controls beside each check that legitimate work still functions, since a sandbox that refuses everything would pass the first kind of test. A second package attacks at build time. We ran both in the deployed topology—the runtime image as runtime and as agents container on an internal network—on Linux 6.18 (WSL2), which offers every Landlock feature used, so no test was skipped for a missing kernel feature. All 83 tests passed (58 confinement, 25 spawner; 88 s). Table 4 groups them.

What is not evaluated. No test calls a real model, so we do not measure how often a model resists injection or chooses well; running DecentAI's gates under an injection benchmark such as AgentDojo [4] would quantify utility under attack and is future work. We report no latency or throughput overheads, nor behaviour at scale. Confinement results hold for the kernel and architecture tested; a kernel flaw is a way past every layer. The tests establish conformance to the stated properties, not formal completeness.

10 Related Work

Attacks and benchmarks. Prompt injection was shown first against direct prompts [10] and then indirectly, through content an application retrieves [7]. InjecAgent [18] and AgentDojo [4] measure how often tool-using agents follow injected instructions, and ToolEmu [12] uses an emulated sandbox to surface risky agent actions. These works motivate our threat model; DecentAI does not reduce the rate at which a model is fooled, but what the fooled model can do.

System-level defences. A line of work moves the defence out of the model. CaMeL [5] has a privileged model write

Table 2. Adversaries, what they can do, and what holds them.

Adversary	Can	Held by
A1 model	emit any proposal with any inputs; write any prose	E1–E6 outside the model; deny-by-default grants; the level gate; evidence only from the trace
A2 injector	choose text the model reads, and so steer proposals	the same gates; grants, levels, manifest hosts, the approval hash and credential binding derive from no model output; a denial refuses the named hosts for the request
A3 agent author	arbitrary code in the worker during a call	approval pinned to commit and digest; per-operation resource mediation; uid, Landlock, seccomp, limits; egress to declared hosts; confined builder
A4 other person	their own session, cookie or API key	per-request identity; deny-by-default policy; visibility inside queries; tenant scoping; `Origin` check on cookie sockets
A5 compromised worker	A3, plus attacks on co-located workers	per-agent uid and Landlock domain; seccomp; an internal network leading only to the runtime
A6 compromised runtime	every delegation it currently holds	no database route, decryption key or signing key; 41-action fence; cannot decide approvals; stop-everything withdraws its delegations

Table 3. Test suites (test functions; parametrization makes executed counts higher). Runs of 15 October 2026.

Suite	Tests	Exercises
Runtime	1,031	executor gates, approvals, stops, proxy, evidence
Backend	924	identity, policy invariants, delegation fence, encryption, OAuth, audit
Cross-component	180	approval-to-package path; end-to-end chat
Example agent	24	an agent run as its author would
Total	2,159	
of which live sandbox	83	hostile agent, deployed topology

a program from the trusted query, run by an interpreter that tracks the provenance of values and enforces capability policies on tool calls, so untrusted data cannot change control flow. FIDES [3] applies information-flow control to the agent's planner with confidentiality and integrity labels. Beurer-Kellner et al. [2] catalogue design patterns that bound what injected data can influence. Progent [15] enforces fine-grained, deterministic privilege policies over tool calls. IsolateGPT [17] isolates third-party apps in an LLM system from one another and mediates their interaction.

DecentAI is closest to Progent in enforcing deterministic policy on every call, and to IsolateGPT in isolating third-party code; it differs in scope rather than mechanism. It is a deployed, multi-user platform in which per-call policy is one layer among several: authenticated identity and grants, approvals bound to the exact call, kernel-level confinement of the third-party code that implements tools—its files, system calls and network destinations—, credential mediation that keeps secrets from both model and client, and a privilege-separated split between backend and runtime. Conversely, DecentAI has no information-flow tracking: an injection can still steer a granted function below the trust level (Section 4), which CaMeL- and FIDES-style provenance tracking addresses. The approaches are complementary.

Protection mechanisms. The design follows complete mediation and least privilege [14] and the reference-monitor requirements of tamper-resistance and analyzability [1]; the backend–runtime split follows privilege separation [11]. Per-agent confinement uses the same move as capability-mode sandboxing [16]: reduce ambient authority, then grant explicitly, here with Landlock, seccomp and an egress proxy. Exact-call approval resembles a mobile permission prompt, but is decided per invocation and grants no lasting capability.

11 Limitations and Discussion

Residual risk follows the boundaries. *Injection below the trust level*: a granted function at or below ℓ_c runs on the model's word, so trust levels and least-privilege grants are security decisions, and level 3 removes approval by design. *A legitimate agent misusing its credential*: an approved agent can use what it is lent against its declared hosts; the proxy cannot see inside TLS, and a persistent worker can keep a token in memory. *Shared workers*: for efficiency, the workers of one agent serve all its authorized people, so separate uids isolate agents, not people using the same agent. *Runtime trust*: the level gate runs in the runtime, so A6 can skip cards within the delegations it holds. *Platform*: seccomp targets x86-64 and arm64 and can be disabled deployment-wide; older kernels lack some Landlock controls; memory is a shared, sampled budget and disk use is observed, not capped. *Accountability*: append-only is enforced by interfaces, not cryptographic chaining. *Leaks by content*: a secret a person pastes into a prompt, or an agent returns as output, is ordinary data. *Evidence*: the model still chooses which recorded result to show and how to title it, and a result is stored only if storage succeeds; the guarantee is that what is rendered was recorded, not that everything recorded is rendered.

Design choices. Several limits are the price of a choice. *Persistent per-agent workers*, rather than one process per call, keep heavy environments (a browser, scientific libraries) warm and make calls fast; the cost is the shared state above. *A seccomp denylist*, rather than an allowlist, lets arbitrary Python libraries run; uid, Landlock and network layers are what we rely on, and seccomp narrows the kernel surface behind them. *Per-call approval*, rather than per-session

Table 4. Escape attempts by the hostile agent, all refused, and the legitimate operations verified alongside (83 tests, Linux 6.18, no skips).

Property	Attempts (all refused)	Refused by	Still works
Own files	read runtime settings; write its own package, environment or install directory; read or write another agent's home or package; read platform code; write world-writable paths	uid ownership; Landlock	read what it runs from; the shared spool; home emptied on every start
Own identity	signal the runtime; use the spawn helper to become another agent's uid; keep state across restarts	uid separation; `no_new_privs`; empty capabilities; helper's cleanup	runs as its own uid; stopping it ends all it started
Declared hosts	connect past the proxy; reach the runtime or spawner; resolve a name directly; reach an undeclared host, any host with none declared, or a blocked site with `hosts: any`	nftables owner rule; proxy; Landlock TCP rule	its declared host; a credential's host and a card-approved host, each for that call only
System calls	open an unused socket family; `ptrace`; create a namespace; connect to another agent's abstract socket	seccomp; Landlock scoping	its own Unix socket; programs it runs are fenced with it
Builds	read settings, write the environment, reach hosts other than the index, fetch from elsewhere, never end	builder uid; proxy pass; five-minute kill	wheels built, installed; only wheels remain

consent, makes the person see the exact recipient and body of what leaves; its usability cost—approval fatigue at low trust levels—is real and not measured here. *The level gate in the runtime* keeps parked calls next to the state they resume in; the backend's holding of the card and of *h* keeps the decision out of the runtime's reach, but not the gate itself.

These suggest the next steps: per-person or per-call workers, moving the level gate into the backend, information-flow tracking for values that cross from tool output into later calls, tamper-evident logging, and measurement under injection benchmarks. The broader point is that injection resistance in the model and authority outside it are different problems. The first may never be solved; the second can be engineered, audited and tested with the tools security already has.

12 Conclusion

Tool-using assistants should not inherit authority from the text they process. DecentAI separates model proposals from authenticated policy, exact-call approval, confined execution and trace-backed evidence, and splits authority so that the components exposed to models and third-party code hold the least. Its tests show the gates and sandbox refusing the evaluated violations and escapes while legitimate work proceeds. The result is not an injection-proof model; it is a system in which a model's failure has a small, explicit and observable blast radius.

Availability. Code, tests and the hostile fixture are at `https://github.com/decentai-io/decentai` under the Apache 2.0 license. The scripted-model suites need no model key; the live suites need the runtime and agents images, an internal Docker network, `NET_ADMIN` for the egress rule, and a kernel with the Landlock features used. A longer companion paper describes every mechanism with the file that implements it.

References

[1] James P. Anderson. Computer security technology planning study. Technical Report ESD-TR-73-51, Electronic Systems Division, Air Force Systems Command, 1972.

[2] Luca Beurer-Kellner, Beat Buesser, Ana-Maria Creţu, Edoardo Debenedetti, Daniel Dobos, Daniel Fabian, Marc Fischer, David Froelicher, Kathrin Grosse, Daniel Naeff, Ezinwanne Ozoani, Andrew Paverd, Florian Tramèr, and Václav Volhejn. Design patterns for securing LLM agents against prompt injections. arXiv:2506.08837, 2025.

[3] Manuel Costa, Boris Köpf, Aashish Kolluri, Andrew Paverd, Mark Russinovich, Ahmed Salem, Shruti Tople, Lukas Wutschitz, and Santiago Zanella-Béguelin. Securing AI agents with information-flow control. arXiv:2505.23643, 2025.

[4] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *NeurIPS Datasets and Benchmarks Track*, 2024. arXiv:2406.13352.

[5] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. arXiv:2503.18813, 2025.

[6] Morris Dworkin. Recommendation for block cipher modes of operation: GCM and GMAC. Technical Report SP 800-38D, National Institute of Standards and Technology, 2007.

[7] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, pages 79–90, 2023. doi: 10.1145/3605764.3623985.

[8] Dick Hardt. The OAuth 2.0 authorization framework. RFC 6749, 2012.

[9] Linux kernel documentation. Landlock: unprivileged access control. `https://docs.kernel.org/userspace-api/landlock.html`, 2026.

[10] Fábio Perez and Ian Ribeiro. Ignore previous prompt: Attack techniques for language models. arXiv:2211.09527, 2022.

[11] Niels Provos, Markus Friedl, and Peter Honeyman. Preventing privilege escalation. In *Proceedings of the 12th USENIX Security Symposium*, 2003.

[12] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an LM-emulated sandbox. In *International Conference on Learning Representations (ICLR)*, 2024. arXiv:2309.15817.

[13] Nat Sakimura, John Bradley, and Naveen Agarwal. Proof key for code exchange by OAuth public clients. RFC 7636, 2015.

[14] Jerome H. Saltzer and Michael D. Schroeder. The protection of information in computer systems. *Proceedings of the IEEE*, 63(9):1278–1308, 1975. doi: 10.1109/PROC.1975.9939.

[15] Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. Progent: Securing AI agents with privilege control. arXiv:2504.11703, 2025.

[16] Robert N. M. Watson, Jonathan Anderson, Ben Laurie, and Kris Kennaway. Capsicum: Practical capabilities for UNIX. In *Proceedings of the 19th USENIX Security Symposium*, 2010.

[17] Yuhao Wu, Franziska Roesner, Tadayoshi Kohno, Ning Zhang, and Umar Iqbal. IsolateGPT: An execution isolation architecture for LLM-based agentic systems. In *Network and Distributed System Security Symposium (NDSS)*, 2025. arXiv:2403.04960.

[18] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, 2024. arXiv:2403.02691.